Semana 03 — Alcance, activos y reglas de enfrentamiento

Grupo 1 · rol Rojo · ejemplo de trabajo

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

Curso	CYBERSEGURIDAD — Ciberseguridad Aplicada
Semana	03 de 10
Fase	1 — Fundamentos, criptografía y marco legal
Grupo	1
Rol	Rojo
Entrega	GitHub, carpeta semana_03/
Corte	Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

1 Tu rol en la práctica

Ejecuta la técnica ofensiva sobre el objetivo autorizado: prepara el entorno, lanza el ataque, registra comandos y payloads, y guarda cada salida con su hash.

- Confirmar el objetivo autorizado y preparar el entorno antes de la primera captura.
- Ejecutar la técnica de la semana en el orden de los pasos y guardar cada salida cruda con su hash.
- Redactar la reproducción: comando, salida esperada y salida obtenida, sin retocar la evidencia.

2 Qué aporta este rol al entregable

Evidencia cruda en semana_NN/evidencia y el apartado de reproducción del informe.

3 Ejemplo paso a paso

El rol Rojo define primero el campo de juego: que se toca, que no se toca, en que ventana y que se hace si aparece algo critico. Sin eso, cualquier hallazgo es inutilizable aunque sea cierto.

3.1 Convertir el laboratorio en un alcance escrito

El alcance se escribe con activos observados, no con lo que se recuerda. Cada linea del inventario se puede rastrear a una salida de ‘docker compose ps‘.

```
mkdir -p semana_03/evidencia
docker compose ps > semana_03/evidencia/activos_observados.txt
date -u +%Y-%m-%dT%H:%M:%SZ > semana_03/evidencia/ventana.txt
git log -1 --format='%H %ad' >> semana_03/evidencia/ventana.txt
sha256sum semana_03/activos_observados.txt \
  > semana_03/evidencia/activos_observados.sha256
```

3.2 Separar incluido, excluido y fuera de alcance

Excluir es tan importante como incluir: la red del campus, los servicios de la universidad y cualquier host que no sea 127.0.0.1 quedan fuera por escrito.

3.3 Escribir las reglas de enfrentamiento

Las reglas dicen que hacer ante un hallazgo critico y ante datos personales. No son recomendaciones: son detenciones obligatorias con un responsable nombrado y un canal de aviso.

3.4 Firmar y sellar la autorizacion

La autorizacion se firma antes de ejecutar el primer comando. Su hash y su fecha entran en la evidencia para que nadie pueda sustituirla despues.

```
sha256sum semana_03/autorizacion.md > semana_03/evidencia/autorizacion.
   sha256
cat semana_03/evidencia/autorizacion.sha256
```

3.5 Activo, decision y limite aplicable

Activo, decision y limite aplicable

Activo	Incluido	Limite operativo	Ventana	Responsable
DVWA en 127.0.0.1:8081	Si	Pruebas de inyeccion sin borrar datos	Sesion de laboratorio	Grupo 1
Juice Shop en 127.0.0.1:3000	Si	Sin denegacion de servicio ni fuerza bruta masiva	Sesion de laboratorio	Grupo 1
SSH del contenedor en 2222	Si	Maximo 20 intentos por cuenta	Sesion de laboratorio	Grupo 1
Red del campus	No	Fuera de alcance por escrito	No aplica	Grupo 1
Datos personales reales	No	Si aparecen, se detiene y se avisa	Inmediato	Grupo 1

La columna de limite se llena con una regla operativa concreta; "con cuidado" no es un limite verificable.

4 Qué guardar en el repositorio

Se entrega la autorizacion firmada con activos, exclusiones, ventana y reglas de enfrentamiento, mas el hash que la sella y el inventario que la respalda.

```
semana_03/
|-- autorizacion.md
|-- informe.md
|-- evidencia/
|   |-- activos_observados.txt
|   |-- activos_observados.sha256
|   |-- ventana.txt
|   `-- autorizacion.sha256
`-- README.md
```

- Cada activo incluido aparece en la salida de docker compose ps.
- Las exclusiones nombran hosts concretos, no categorias vagas.
- Las reglas de enfrentamiento tienen responsable y canal de aviso.
- El hash de la autorizacion se calculo antes de ejecutar cualquier prueba.

5 Cómo se corrige

Criterio	Peso
Alcance explícito con inclusiones y exclusiones	3,0
Reglas de enfrentamiento operativas	2,5
Tipificación correcta de las conductas del caso	2,0
Juicio fundamentado sobre admisibilidad de la evidencia	1,5
Código de ética firmado individualmente	1,0
Total	**10,0**

- Un hallazgo critico obliga a detenerse y avisar antes de seguir explorando.
- La autorizacion no se modifica despues de firmada; si cambia el alcance, se firma otra.

Recuerda

El trabajo es independiente: cada grupo usa su propio repositorio y su propio laboratorio, y la comparación de resultados es en clase. Corte: Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.